Вредоносные программы: классификация, методы обнаружения

Введение

Тема вредоносных программ — одна из центральных в обеспечении качества функционирования компьютерных систем. Мы уже разбирали, что такое угрозы надёжности, объекты уязвимости и дестабилизирующие факторы. Вредоносные программы — это один из самых опасных и быстро развивающихся классов дестабилизирующих факторов. Они способны вывести из строя систему, уничтожить данные, украсть конфиденциальную информацию, нарушить работу целых организаций и даже нанести вред физическому здоровью людей, если речь идёт о критической инфраструктуре или медицинском оборудовании.

Понимание того, какие бывают вредоносные программы, как они распространяются и какими методами их можно обнаружить, необходимо каждому специалисту по обеспечению качества компьютерных систем. Без этих знаний невозможно ни правильно выбрать средства защиты, ни оценить риски, ни организовать эффективный мониторинг.

В данной лекции мы рассмотрим основные понятия и определения, подробно разберём классификацию вредоносных программ по разным основаниям, изучим методы их обнаружения — от классических сигнатурных до современных методов на основе машинного обучения, а также обсудим, как оценивать эффективность систем обнаружения и какие меры защиты следует применять.

1. Основные понятия и определения

Вредоносная программа (malware, от английского malicious software) — это любое программное обеспечение, специально разработанное для причинения вреда компьютеру, серверу, компьютерной сети или пользователю. Вредоносные программы могут быть созданы для разных целей: кражи данных, повреждения файлов, блокировки системы, получения несанкционированного доступа, накрутки рекламы, майнинга криптовалюты и многого другого. Но всех их объединяет одно — они действуют во вред владельцу системы, часто без его ведома.

Полезная нагрузка (payload) — это основная вредоносная функция, которую выполняет программа после заражения системы. Вредоносная программа может состоять из нескольких частей: механизма распространения, механизма скрытности и полезной нагрузки. Например, червь может распространяться по сети (механизм распространения), маскироваться под системный процесс (механизм скрытности) и шифровать файлы (полезная нагрузка). Понимание того, какую именно нагрузку несёт вредоносная программа, важно для оценки возможного ущерба.

Ключевые характеристики вредоносных программ помогают отличить их от легитимного программного обеспечения. К ним относятся:

- **Самовоспроизведение — способность к размножению и распространению без участия пользователя или с минимальным участием**. Не все вредоносные программы обладают этой способностью (например, трояны обычно не размножаются), но многие.

- **Скрытность — использование методов для избежания обнаружения**. Это может быть шифрование кода, полиморфизм, обфускация, маскировка под системные процессы, использование руткитов.

- **Деструктивность — нанесение ущерба системе или данным**. Ущерб может быть разным: от косметических изменений до полного уничтожения данных.

- **Несанкционированный доступ — получение контроля над системой без ведома пользователя**. Это может быть доступ к файлам, к сети, к оборудованию, к учётным записям.

Важно понимать, что грань между вредоносной и легитимной программой не всегда очевидна. Некоторые программы, которые формально не являются вредоносными, могут вести себя нежелательным образом: показывать навязчивую рекламу, собирать телеметрию, ограничивать функциональность. Такие программы называют нежелательными (potentially unwanted programs, PUP). Они не всегда классифицируются как вредоносные, но могут создавать риски.

2. Классификация вредоносных программ

Классифицировать вредоносные программы можно по разным основаниям. Каждая классификация помогает увидеть свой аспект угрозы. Рассмотрим три основных основания: по механизму распространения, по функциональности и по способу монетизации.

2.1. По механизму распространения

По механизму распространения выделяют вирусы, черви и трояны. Это наиболее классическая классификация, которая существует с первых дней компьютерных эпидемий.

Вирусы — это программы, которые прикрепляются к другим программам и размножаются. Ключевая особенность вирусов в том, что они требуют вмешательства пользователя для активации. Вирус не может запуститься сам по себе — он активируется, когда пользователь запускает заражённый файл. Вирусы могут заражать разные типы объектов. Файловые вирусы заражают исполняемые файлы, встраивая свой код в тело программы. Загрузочные вирусы заражают загрузочные секторы дисков, активируясь при загрузке системы. Макровирусы заражают документы с макросами, например, файлы Microsoft Office, и активируются при открытии документа.

Вирусы были особенно популярны в 1990-е и начале 2000-х годов, когда обмен файлами через дискеты и электронную почту был основным способом распространения. С развитием сетей и интернета на первый план вышли черви.

Черви — это самостоятельные программы, которые распространяются по сетям. Их ключевая особенность в том, что они не требуют вмешательства пользователя. Червь самостоятельно находит уязвимости в сети и заражает новые системы. Примерами могут служить:

- **ILOVEYOU** (2000) — червь, распространявшийся по электронной почте. Пользователи получали письмо с темой «ILOVEYOU» и вложением, при открытии которого червь заражал систему и рассылал себя по всем контактам. Ущерб оценивается в 15 миллиардов долларов.

- **Conficker** (2008) — червь, заразивший более 15 миллионов компьютеров по всему миру. Он использовал уязвимость в Windows и распространялся через локальные сети и съёмные носители.

- **WannaCry** (2017) — червь-шифровальщик, который заразил более 200 тысяч компьютеров в 150 странах. Он использовал уязвимость в протоколе SMB и требовал выкуп за расшифровку данных.

Черви представляют особую опасность, потому что могут распространяться очень быстро и наносить массовый ущерб.

Трояны — это программы, которые маскируются под легитимное программное обеспечение. Их ключевая особенность в том, что они не размножаются самостоятельно. Троян проникает в систему, потому что пользователь сам его запускает, думая, что это полезная программа. Трояны могут выполнять разные функции: кража данных (трояны-похитители), удалённое управление (бэкдоры), скачивание других вредоносных программ (дропперы). Трояны часто распространяются через фишинговые письма, поддельные сайты, пиратские копии программ.

2.2. **По функциональности**

По функциональности вредоносные программы делятся на несколько категорий, каждая из которых выполняет свою задачу.

Шпионские программы (spyware) — это программы для тайного сбора информации. Они могут собирать разные данные: нажатия клавиш (кейлоггеры), изображения с экрана (экранные шпионы), историю посещений сайтов (трекеры cookies), учётные данные, переписку. Собранная информация передаётся злоумышленнику и может использоваться для кражи денег, шантажа, промышленного шпионажа.

Рекламные программы (adware) — это программы для показа нежелательной рекламы. Они часто поставляются в составе бесплатного программного обеспечения. Adware может замедлять систему, вторгаться в приватность, перенаправлять поисковые запросы. Формально adware не всегда является вредоносным, но может создавать серьёзные неудобства и риски.

Руткиты (rootkits) — это программы для скрытия присутствия других вредоносных программ. Руткит маскирует вредоносный код, чтобы его не обнаружили антивирусы и другие средства защиты. Руткиты могут работать на разных уровнях: на пользовательском уровне, на уровне ядра операционной системы, на уровне гипервизора, на уровне прошивки (firmware). Чем глубже уровень, тем сложнее обнаружить и удалить руткит. Руткиты на уровне прошивки особенно опасны, потому что они сохраняются даже после переустановки операционной системы.

2.3. По способу монетизации

По способу монетизации выделяют рансомеры, ботнеты и криптоджекинги. Эта классификация отражает то, как злоумышленники получают выгоду от своих действий.

Рансомеры (ransomware) — это программы, которые шифруют данные и требуют выкуп за их расшифровку. Рансомеры стали особенно популярны в последние годы. Выделяют несколько типов. Крипто-рансомеры шифруют данные, делая их недоступными. Локер-рансомеры блокируют доступ к системе, не шифруя данные. Доксинг-рансомеры угрожают опубликовать украденные данные, если выкуп не будет выплачен. Известные атаки: WannaCry, Petya, Locky. Рансомеры особенно опасны для организаций, потому что потеря данных может привести к остановке бизнеса.

Ботнеты (botnets) — это сети заражённых компьютеров, управляемых злоумышленником. Каждый заражённый компьютер называется «ботом» и может выполнять команды злоумышленника. Ботнеты используются для разных целей: рассылки спама, DDoS-атак, клик-фрода (накрутки кликов), майнинга криптовалют. Ботнеты могут включать миллионы компьютеров, что делает их мощным инструментом для масштабных атак.

Криптоджекинги (cryptojacking) — это использование ресурсов компьютера для майнинга криптовалют. Злоумышленник заражает компьютер и заставляет его майнить криптовалюту, забирая себе прибыль. Криптоджекинг может оставаться незамеченным долгое время, потому что он не разрушает систему, а лишь замедляет её работу и увеличивает расход электроэнергии. Способы заражения: вредоносные расширения браузеров, заражённые веб-сайты, скачанное ПО.

3. Методы обнаружения вредоносных программ

Обнаружение вредоносных программ — это сложная задача, потому что злоумышленники постоянно совершенствуют методы маскировки. Существует несколько подходов к обнаружению, каждый из которых имеет свои преимущества и ограничения.

3.1. Сигнатурные методы

Сигнатурные методы — это самый старый и самый распространённый подход к обнаружению вредоносных программ. Он основан на сравнении файлов с базой известных сигнатур.

Принцип работы. Сигнатура — это уникальный идентификатор вредоносной программы, который позволяет отличить её от легитимных файлов. Сигнатура может быть хешем файла (MD5, SHA-1, SHA-256), последовательностью байтов, характерной для конкретного вируса, или шаблоном сетевого трафика. Когда антивирус проверяет файл, он вычисляет его хеш и сравнивает с базой сигнатур. Если хеш совпадает — файл считается вредоносным.

Преимущества. Сигнатурные методы обладают высокой точностью обнаружения известных угроз. Они не дают ложных срабатываний (если сигнатура верна), работают быстро и не требуют много ресурсов. Для известных угроз это самый надёжный метод.

Недостатки. Главный недостаток сигнатурных методов в том, что они не обнаруживают новые (zero-day) угрозы. Если сигнатуры для вредоносной программы ещё нет в базе, антивирус её не обнаружит. Кроме того, сигнатурные методы требуют постоянного обновления баз. И, наконец, они уязвимы к обфускации и полиморфизму — злоумышленники могут изменять код программы так, чтобы сигнатура не совпадала, но функциональность сохранялась.

Типы сигнатур. Сигнатуры могут быть файловыми (уникальные последовательности байтов в файле), сетевыми (характерные шаблоны сетевого трафика) и поведенческими (характерные последовательности действий). Файловые сигнатуры используются для обнаружения заражённых файлов, сетевые — для обнаружения атак через сеть, поведенческие — для обнаружения подозрительной активности.

3.2. Эвристические методы

Эвристические методы — это следующий шаг в развитии обнаружения. Они основаны на анализе поведения и характеристик программы, а не на сравнении с известными сигнатурами.

Принцип работы. Эвристический анализ использует правила и алгоритмы для выявления подозрительного поведения. Если программа делает что-то, что обычно делают вредоносные программы (например, пытается изменить системные файлы, отключить антивирус, отправить данные на неизвестный сервер), она может быть признана подозрительной.

Методы эвристического анализа. Эвристический анализ может быть статическим и динамическим. Статический анализ выполняется без запуска программы: анализируется структура исполняемого файла, ищутся подозрительные строки и функции, анализируются импортируемые библиотеки. Динамический анализ выполняется с запуском программы в изолированной среде (песочнице): мониторятся системные вызовы, анализируются изменения в системе.

Преимущества. Эвристические методы позволяют обнаруживать новые и неизвестные угрозы. Они эффективны против полиморфных вирусов, которые изменяют свой код, но сохраняют поведение.

Недостатки. Эвристические методы дают более высокий процент ложных срабатываний — легитимные программы могут вести себя подозрительно. Они создают более высокую нагрузку на систему. И они сложны в настройке и калибровке: нужно найти баланс между чувствительностью и ложными срабатываниями.

3.3. **Поведенческие методы**

Поведенческие методы — это развитие эвристических методов. Они основаны на мониторинге поведения программ в реальном времени.

Принцип работы. Поведенческий анализ отслеживает действия программ и выявляет аномалии. Если программа делает что-то, что не соответствует её заявленной функциональности, это может быть признаком вредоносной активности.

Техники обнаружения. Поведенческие методы используют несколько техник. Мониторинг системных вызовов отслеживает вызовы API: если программа вызывает функции, которые обычно используются вредоносными программами, это подозрительно. Контроль целостности файлов обнаруживает несанкционированные изменения системных файлов. Анализ сетевой активности выявляет подозрительные соединения: например, программа пытается подключиться к известному командному серверу ботнета. Контроль доступа мониторит попытки несанкционированного доступа к защищённым ресурсам.

Показатели поведения. Поведенческие методы анализируют разные показатели: частоту и последовательность системных вызовов, паттерны доступа к файлам и реестру, характер сетевых соединений, использование системных ресурсов. Например, если программа начинает активно шифровать файлы и требовать выкуп, это классическое поведение рансомера.

Преимущества. Поведенческие методы позволяют обнаруживать сложные угрозы, которые маскируются под легитимные программы. Они эффективны против fileless-угроз, которые не оставляют файлов на диске.

Недостатки. Поведенческие методы требуют больше ресурсов, потому что мониторинг в реальном времени создаёт нагрузку. Они могут давать ложные срабатывания, если легитимная программа ведёт себя необычно. И они требуют времени для обнаружения: пока программа не начнёт действовать, её не обнаружат.

4. Современные технологии обнаружения

Современные технологии обнаружения вредоносных программ выходят за рамки классических сигнатурных и эвристических методов. Они используют машинное обучение, песочницы и анализ поведения в памяти.

4.1**. Машинное обучение и искусственный интеллект**

Применение. Машинное обучение используется для нескольких задач. Классификация — определение принадлежности файла к вредоносному или легитимному ПО. Кластеризация — группировка похожих образцов для выявления семейств вредоносных программ. Аномалия детекшн — выявление отклонений от нормального поведения системы.

Используемые алгоритмы. Для обнаружения вредоносных программ используются разные алгоритмы. Деревья решений и случайные леса — простые и интерпретируемые модели, которые хорошо работают на табличных данных. Метод опорных векторов (SVM) — эффективен для классификации. Нейронные сети — более сложные модели, которые могут анализировать изображения, последовательности, графы. Свёрточные нейросети (CNN) используются для анализа изображений бинарных файлов: файл представляется как изображение, и нейросеть ищет визуальные паттерны, характерные для вредоносных программ. Рекуррентные нейросети (RNN) используются для анализа последовательностей действий. Графовые нейросети используются для анализа взаимосвязей в системе.

Преимущества. Машинное обучение позволяет обнаруживать новые угрозы, которые не похожи на известные. Оно может адаптироваться к изменяющимся атакам.

Недостатки. Машинное обучение требует больших объёмов данных для обучения. Модели могут быть уязвимы к состязательным атакам (adversarial attacks), когда злоумышленник специально подбирает данные, чтобы обмануть модель. И модели могут быть «чёрными ящиками», что затрудняет объяснение решений.

4.2. Поведенческий анализ в песочнице

Песочница (sandbox) — это изолированная виртуальная среда, в которой можно безопасно запускать подозрительные файлы.

Принцип работы. Подозрительный файл запускается в песочнице, а система мониторит все его действия: какие файлы он создаёт, какие процессы запускает, к каким серверам подключается. На основе собранных данных принимается решение о вредоносности.

Преимущества. Песочница безопасна для основной системы: даже если файл окажется вредоносным, он не нанесёт вреда. Она позволяет детально анализировать поведение программы. И она обнаруживает сложные угрозы, которые маскируются под легитимные программы.

Ограничения. Песочница требует много ресурсов: запуск виртуальной машины и мониторинг всех действий создают нагрузку. Время анализа ограничено: некоторые вредоносные программы активируются с задержкой или только при определённых условиях. Продвинутые угрозы могут обходить песочницу, определяя, что они запущены в виртуальной среде, и ведя себя безобидно.

4.3. **Угрозы без файлов (Fileless Malware)**

Fileless-угрозы — это вредоносные программы, которые не оставляют файлов на диске. Они работают только в оперативной памяти и используют легитимные инструменты системы, такие как PowerShell, WMI, макросы.

Особенности. Fileless-угрозы сложно обнаружить классическими методами, потому что они не создают файлов, которые можно проверить. Они используют легитимные инструменты, которые не вызывают подозрений. И они работают только в памяти, что затрудняет анализ.

Методы обнаружения. Для обнаружения fileless-угроз используются специальные методы. Мониторинг процессов в памяти анализирует запущенные процессы и ищет подозрительные паттерны. Аудит использования системных инструментов отслеживает PowerShell, WMI и другие инструменты: если они используются необычным образом, это может быть признаком атаки. Контроль целостности системных компонентов обнаруживает изменения в системных файлах и реестре.

5. Антивирусные технологии и системы

Антивирусные системы — это комплекс программных средств, которые обнаруживают и удаляют вредоносные программы. Современные антивирусы включают несколько компонентов.

5.1. Компоненты антивирусных систем

Сканеры — это компоненты, которые проверяют файлы на наличие вредоносного кода. Сканеры могут быть трёх типов. On-access scanner проверяет файлы при доступе к ним: когда пользователь открывает файл, сканер проверяет его в реальном времени. On-demand scanner проверяет файлы по запросу пользователя: пользователь может запустить полную проверку системы. Периодическое сканирование — это автоматическая проверка по расписанию: например, каждую ночь антивирус проверяет все файлы.

Мониторы — это компоненты, которые отслеживают активность в реальном времени. Файловые мониторы отслеживают операции с файлами: создание, изменение, удаление. Сетевые мониторы анализируют сетевой трафик: входящие и исходящие соединения. Поведенческие мониторы контролируют активность процессов: какие действия выполняет программа.

Эвристические анализаторы — это компоненты, которые анализируют код и поведение программ. Статические анализаторы анализируют код без запуска: ищут подозрительные строки, функции, структуры. Динамические анализаторы анализируют программу в контролируемой среде: запускают её в песочнице и мониторят поведение.

5.2. **Облачные технологии**

Быстрое обновление. Облачные базы сигнатур обновляются мгновенно: как только появляется новая угроза, сигнатура становится доступна всем пользователям.

Коллективный интеллект. Облачные системы собирают данные от всех пользователей: если один пользователь столкнулся с новой угрозой, информация об этом передаётся в облако и становится доступна другим.

Снижение нагрузки. Анализ переносится в облако: клиентская часть на устройстве пользователя остаётся лёгкой, а мощные серверы в облаке выполняют сложный анализ.

Архитектура. Облачная антивирусная система состоит из клиентской части (лёгкий агент на устройстве), облачной части (мощные серверы для анализа) и базы данных угроз (централизованное хранение информации).

6. **Метрики эффективности обнаружения**

Чтобы оценить, насколько хорошо система обнаружения справляется с задачей, используются специальные метрики. Они основаны на четырёх показателях:

- **TP (True Positive) —** правильно обнаруженные угрозы: система обнаружила вредоносную программу, и она действительно вредоносная.

- **TN (True Negative**) — правильно пропущенные безопасные объекты: система не обнаружила угрозу, и объект действительно безопасен.

- **FP (False Positive) —** ложные срабатывания: система обнаружила угрозу, но объект безопасен.

- **FN (False Negative)** — пропущенные угрозы: система не обнаружила угрозу, но объект вредоносный.

На основе этих показателей вычисляются метрики:

True Positive Rate (TPR) — доля правильно обнаруженных угроз. **Формула: TP / (TP + FN).** Оптимальное значение — не менее 0.95.

False Positive Rate (FPR) — доля ложных срабатываний. **Формула: FP / (FP + TN).** Оптимальное значение — не более 0.01.

Accuracy — общая точность. **Формула: (TP + TN) / (TP + TN + FP + FN).** Оптимальное значение — не менее 0.98.

Precision — точность обнаружения угроз. **Формула: TP / (TP + FP).** Оптимальное значение — не менее 0.95.

Recall — полнота обнаружения. **Формула: TP / (TP + FN).** Оптимальное значение — не менее 0.95.

F1-Score — гармоническое среднее точности и полноты. **Формула: 2 × (Precision × Recall) / (Precision + Recall).** Оптимальное значение — не менее 0.95.

Эти метрики позволяют сравнивать разные системы обнаружения и выбирать оптимальные настройки. Важно понимать, что идеальных систем не существует: всегда есть компромисс между чувствительностью (обнаруживать больше угроз) и специфичностью (меньше ложных срабатываний).

7. Рекомендации по защите

Защита от вредоносных программ — это комплекс мер, которые включают профилактику, технические средства и организационные мероприятия.

7.1. Профилактические меры

Профилактика — это самый эффективный способ защиты. К профилактическим мерам относятся:

- **Регулярное обновление ПО** — установка патчей безопасности закрывает уязвимости, которые используют вредоносные программы.

- **Использование антивирусного ПО** — выбор надёжного решения и его правильная настройка.

- **Ограничение прав пользователей** — работа под учётными записями с ограниченными правами снижает ущерб от вредоносных программ.

- **Обучение пользователей** — повышение осведомлённости о фишинге, подозрительных вложениях, опасных сайтах.

7.2. Технические меры

Технические меры обеспечивают защиту на уровне инфраструктуры. К ним относятся:

- **Межсетевые экраны** — контроль сетевого трафика, блокировка подозрительных соединений.

- **Системы обнаружения вторжений (IDS)** — мониторинг подозрительной активности в сети.

- **Шифрование данных** — защита конфиденциальной информации от кражи.

- **Резервное копирование** — регулярное создание бэкапов позволяет восстановить данные после атаки рансомера.

7.3. Организационные меры

Организационные меры обеспечивают управление безопасностью на уровне организации. К ним относятся:

- **Политика безопасности** — разработка и внедрение правил работы с информацией.

- **Планы реагирования на инциденты** — подготовка к кибератакам: кто что делает, как оповещать, как восстанавливать.

- **Регулярный аудит безопасности** — проверка защищённости систем, выявление уязвимостей.

- **Сотрудничество с CERT** — взаимодействие с центрами реагирования на компьютерные инциденты.

9. Практическое задание

Задание: «Анализ вредоносной программы и выбор методов защиты»

Исходные данные (выберите один вариант):

- Вариант А: Черьв WannaCry (2017).

- Вариант Б: Троян-похититель банковских данных.

- Вариант В: Рансомер, шифрующий файлы на сервере.

- Вариант Г: Fileless-угроза, использующая PowerShell.

- Вариант Д: Криптоджекинг через расширение браузера.

Ход выполнения:

Шаг 1. Опишите вредоносную программу. Укажите:

- тип по механизму распространения;

- тип по функциональности;

- тип по способу монетизации;

- полезную нагрузку;

- способы распространения.

Шаг 2. Оцените риски. Для выбранной вредоносной программы определите:

- какие объекты уязвимости она использует;

- какие угрозы надёжности реализует;

- вероятность заражения;

- тяжесть последствий.

Шаг 3. Выберите методы обнаружения. Для каждого метода (сигнатурный, эвристический, поведенческий) объясните, насколько он эффективен против данной вредоносной программы и почему.

Шаг 4. Предложите меры защиты. Укажите:

- профилактические меры;

- технические меры;

- организационные меры.

Шаг 5. Ответьте на вопрос: какая мера защиты наиболее эффективна для данной вредоносной программы и почему?